

Security Best Practices for Development

Applicable Roles: DEVELOPER, DEVOPS

Authentication & Authorization

- Use JWT with short expiry (15 min access, 7 day refresh)
- Store passwords with bcrypt (cost factor 12+)
- Implement RBAC (role-based access control)
- Use principle of least privilege
- Never hardcode secrets or API keys

API Security

- Rate limit all endpoints
- Validate and sanitize all inputs
- Use HTTPS only
- Implement CORS properly
- Log all auth failures
- Use API versioning
- Never expose internal IDs directly

Data Protection

- Encrypt sensitive data at rest and in transit
- Mask PII in logs and responses
- Implement data retention policies
- Regular database backups (encrypted)
- GDPR/CCPA compliance for user data

OWASP Top 10

Key vulnerabilities to prevent:

1. Broken Access Control
2. Cryptographic Failures
3. Injection (SQL, NoSQL, OS command)
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable Components
7. Auth Failures
8. Data Integrity Failures
9. Logging/Monitoring Failures
10. SSRF

DevSecOps

Shift security left:

- SAST (Static Analysis) in CI pipeline
- Dependency scanning (Dependabot)
- Container image scanning
- Secret scanning in repos
- Penetration testing quarterly
- Bug bounty program